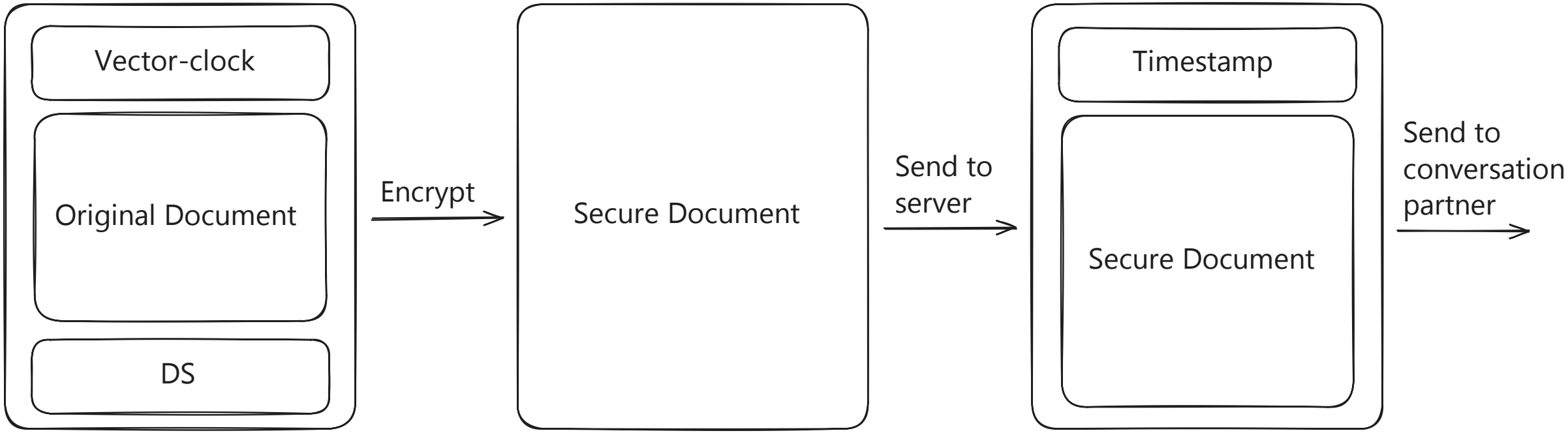
Group A61 - MessagIST

Gonçalo Rua, 1102604
Rodrigo Arêde, 1102606
João Gouveia, 1102611

Secure Documents

Overview



Secure Documents – Vector Clocks

Overview

- Both clients keep track of a vector clock for the conversation.
- Appended to messages being sent.
- Used to check incoming messages.

Secure Documents – Vector Clocks

Why?

- Used to detect out of order or replayed messages.
- The server appends timestamps to the messages according to the order it receives them.
- What if the server is compromised, and suddenly decides to reorder / replay messages?
- Vector clocks reduce the damage the server can make.
- Replayed messages can be detected.
- Out of order messages can be detected unless they were sent concurrently.

Secure Documents – Signing

Overview

- Clients sign messages using elliptic-curve cryptography (Ed25519).
- Allows clients to guarantee that the message hasn't been tampered with.
- Allows clients to confirm the sender's indentity.

Secure Documents – Signing

Why Ed25519?

- Provides the same security as RSA.
- Faster signing.
- Smaller signatures.
- Faster key generation.
- **Smaller keys.**
- Our key recovery strategy is only possible because of the small keys Ed25519 uses.

Secure Documents – Encrypting

Overview

- Clients encrypt messages with AES in CBC mode, using 256-bit keys.
- Allows clients to guarantee that only the parties involved in the conversation can read messages.

Secure Documents – Encrypting

Why AES CBC?

- AES:
  - The "standard" for symmetric cryptography.
  - Exists for more than 20 years - Time-tested.
- CBC:
  - Not possible to detect patterns in the plaintext by analyzing the ciphertext (unlike ECB).

Infrastructure

Overview

- **Public Server (DMZ)**: Acts as na intermediary between clients and the main server.
- **Main Server**: Handles core business logic and interacts with the database.
- **PostgreSQL Database Server**: Stores user data and chat history.
- **Client Application**: User interface for communication.

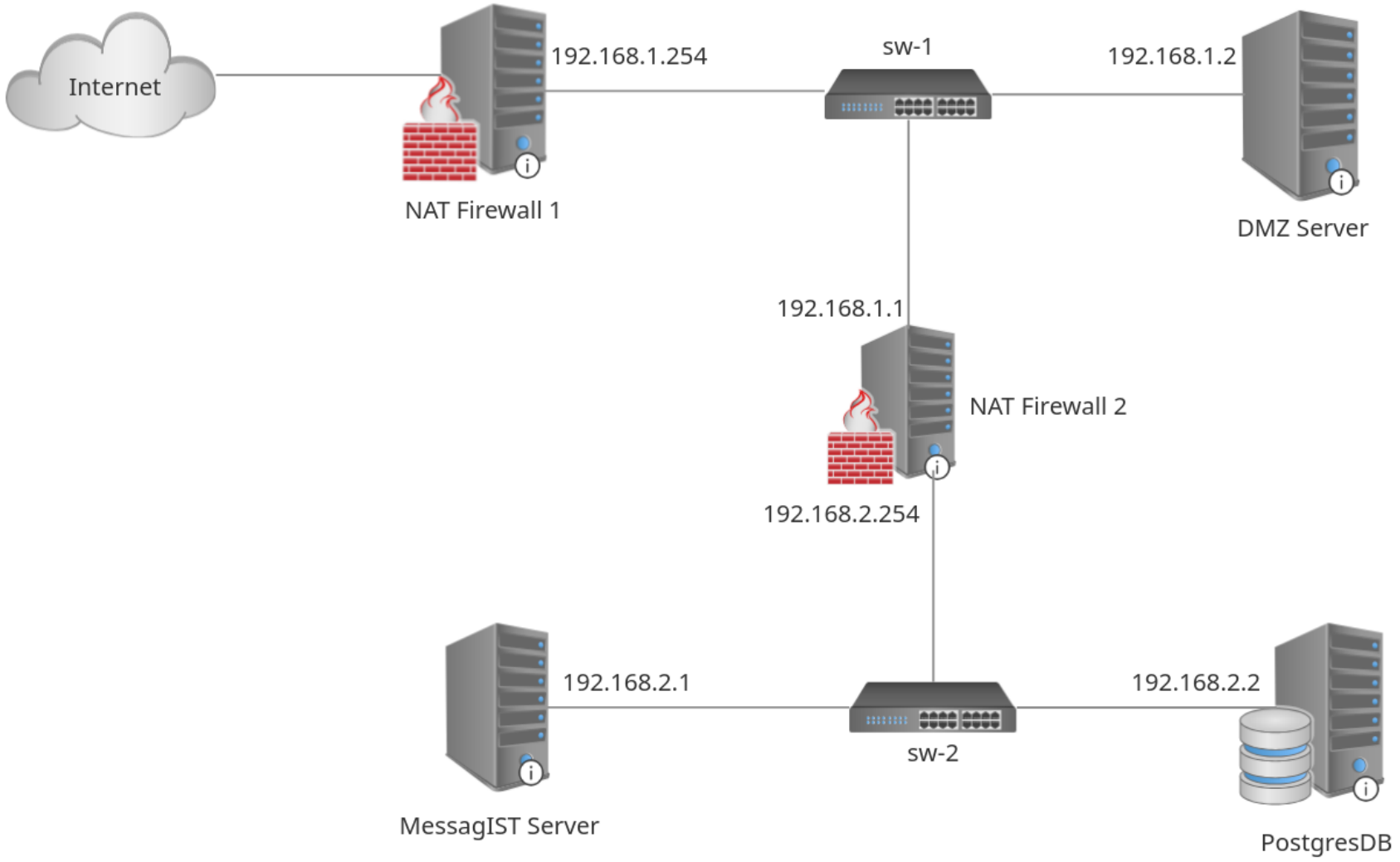
Infrastructure - NAT Firewall Overview

Overview

- **Purpose**:
  - Secure network zones using firewalls.
  - Route traffic between WAN, DMZ, and internal networks.
- **Firewalls**:
  - **Firewall 1**: Handles WAN to DMZ traffic.
  - **Firewall 2**: Handles DMZ to internal traffic.

Infrastructure

Overview



Infrastructure

Why a DMZ?

- Hosts services that need to be accessible from the internet (public-facing API).
- Key Benefits: **Enhanced Security**, **Isolation** and **Controlled Access**.
  - Limits direct access to the internal network.
  - Even if a public-facing server in the DMZ is compromised, attackers cannot directly access internal resources.
  - Allows specific traffic to the DMZ while restricting internal network access to authorized connections only.

Communication Channels

Overview

- Server-Side **TLS**
- Each server:
  - Certificate
  - Private Key

Key Distribution

Overview

	Current Implementation	Real-World Scenario
Server ↔ Server	Certificates manually copied to the required servers.	Certificates manually copied to the required servers.
Public Server ↔ Clients	Certificates distributed manually.	Certificate would be signed by a trusted CA.

Security Challenge

Overview

Requirement	In practice
[SR1]: End-to-end encryption	Sender and receiver exchange a **session a key**
[SR2]: Protocol that allows two users to exchange a key	Protocol that allows two users to agree on a secret.
[SR3]: If a phone is lost, user must be able to recover the message history	Users must be able to recover their asymmetric key pair and session keys.

Key Exchange

Overview

- Users agree on a chat passphrase -> Symetric Key.
- Flexible for users.
- Possible to create strong and memorizable passphrase.
- Exchanged:
  - Verbally.
  - Secure messaging services.

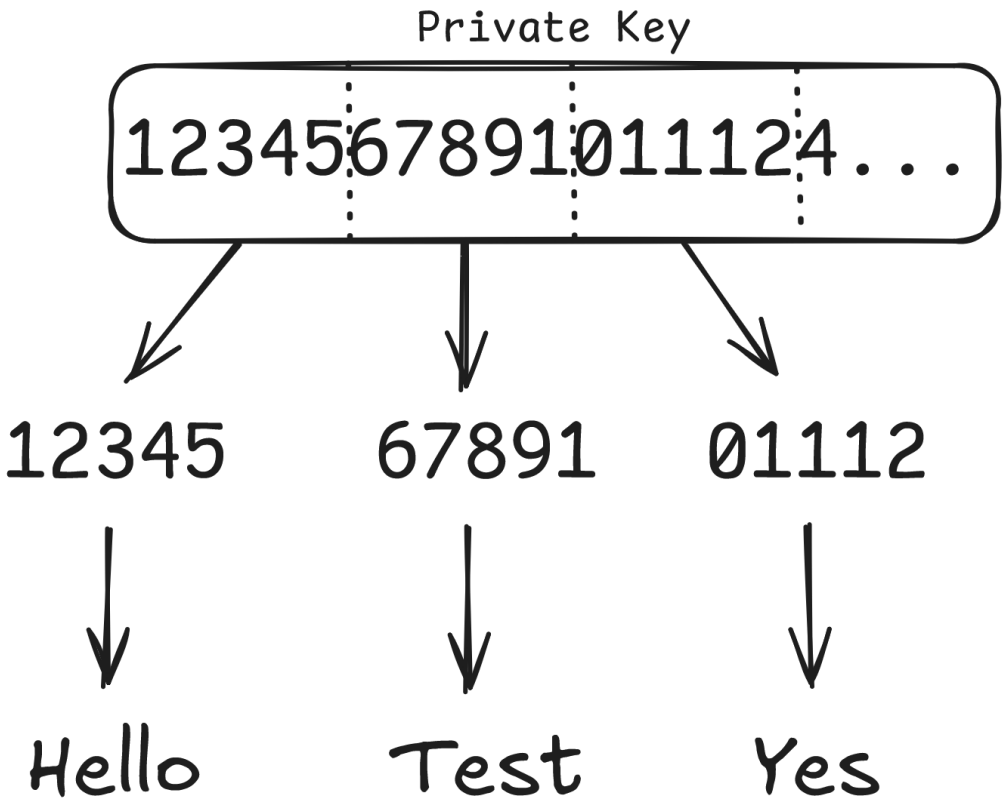
Key Recovery

Overview

- The private key of a user is encoded as a list of 17 words (1 number and 16 actual words).
- This list is shown to the user upon sign up.
- Users should memorize or store this list somewhere safe.
- On login, users are requested to insert this list if their key is not found on local storage.

Key Recovery

Overview



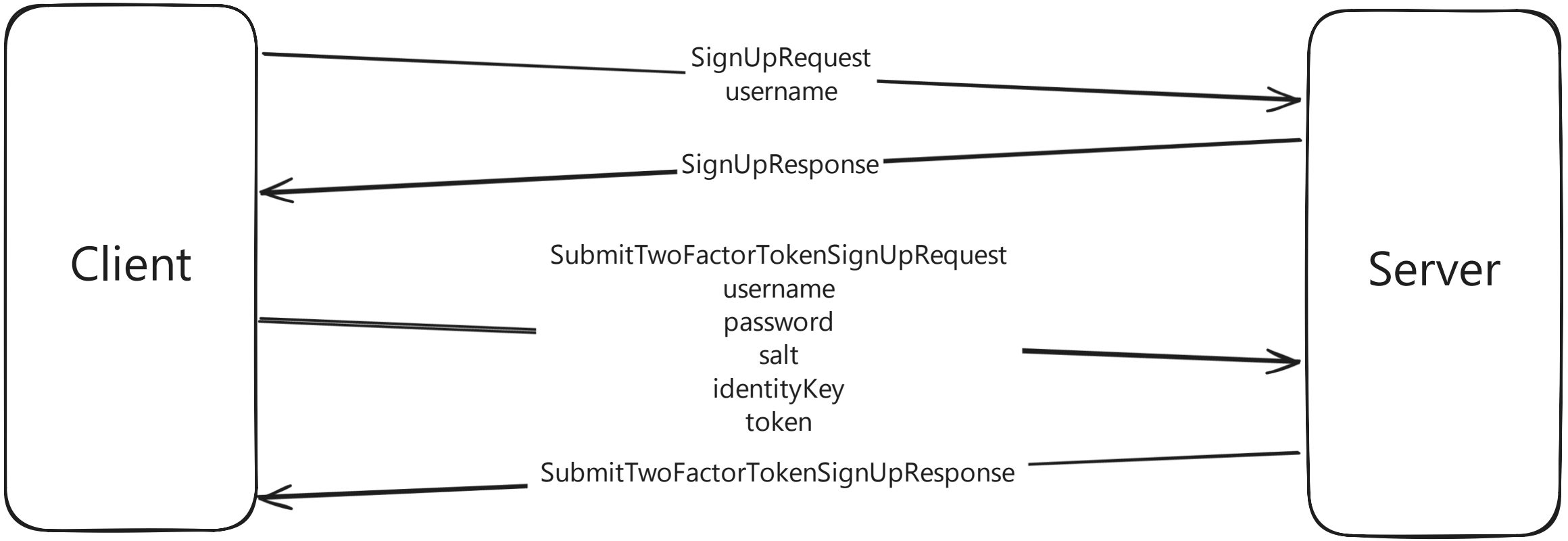
Protocol

Overview

- Sign up.
- Login.
- Establish session with the server.
- Send and receive messages.

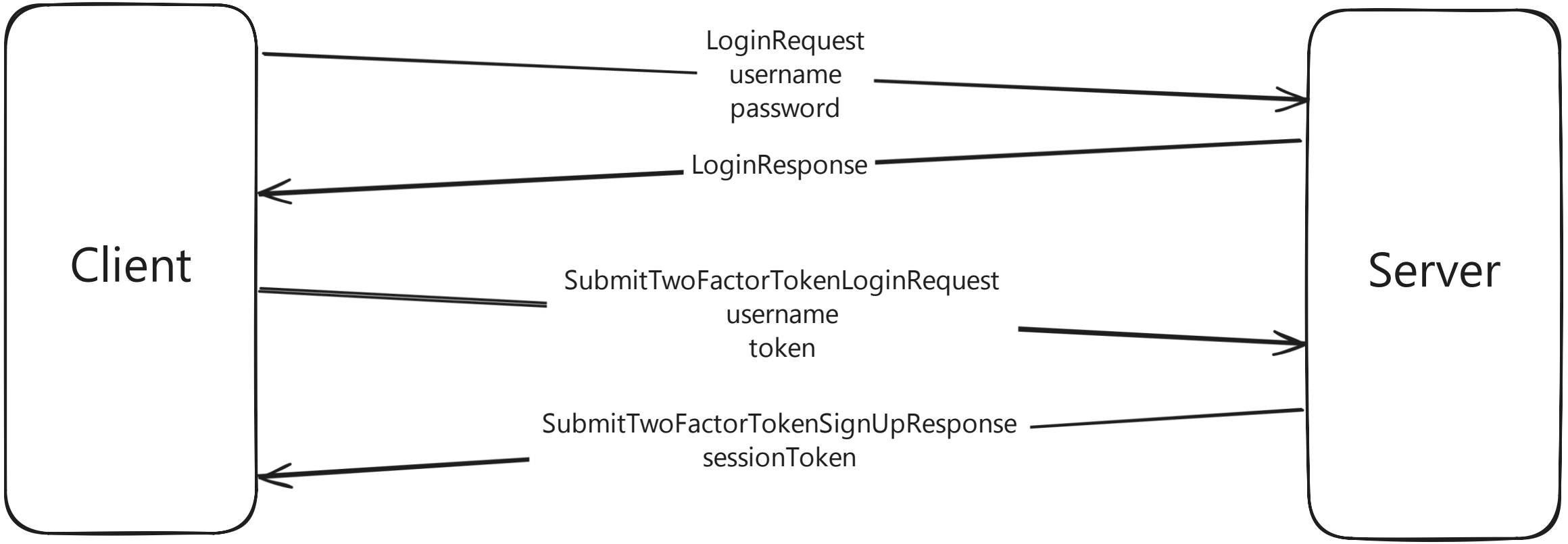
Protocol

Signing Up



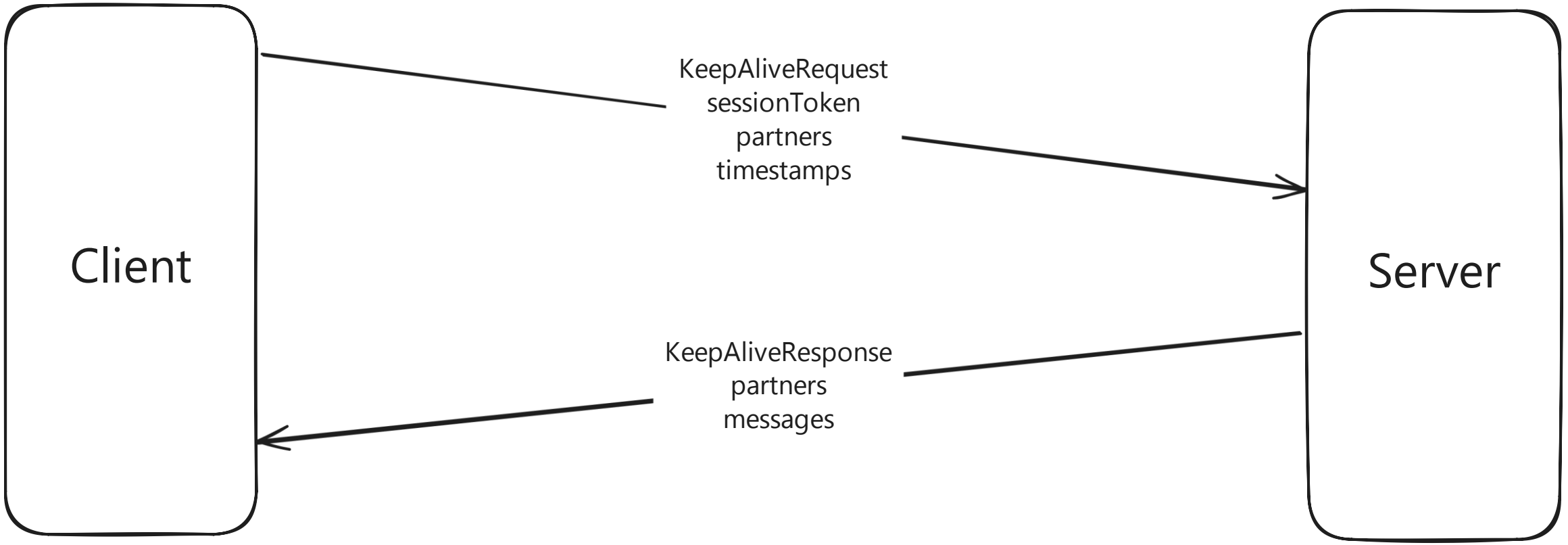
Protocol

Login



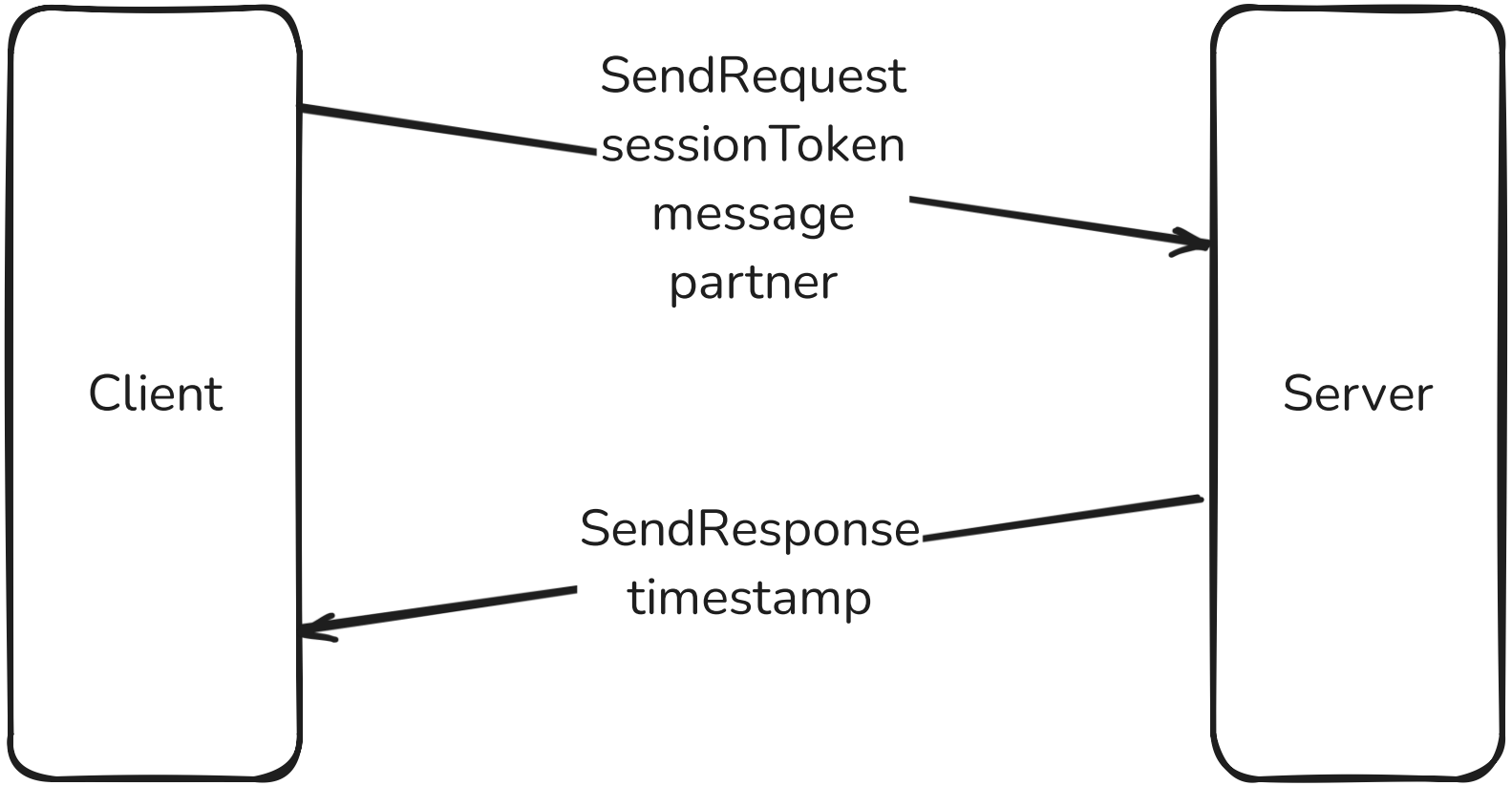
Protocol

Session (and receiving messages)



Protocol

Sending Messages



Conclusion

- We developed a secure messaging service using modern and proven techniques.
- All security requirements were successfully fulfilled.